ETH zürich

Department of Computer Science

Model-driven Privacy

Srđan Krstić, Hoàng Nguyễn, David Basin (Information Security Group)

Motivation

Modern IT systems implement a wide range of privacy requirements. Their sources are manifold, e.g., the EU's General Data Protection Regulation (GDPR) [1], which mandates privacy policies, including

- Art. 5 §1 (b), **purpose-limitation**: *Personal data shall be collected for specified, explicit and legitimate purposes.*
- Art. 7 §1, **data-subject consent**: *Processing shall be lawful only if the data subject has given consent to the processing of his or her personal data.*

Implementation

We implemented two model transformations targeting ASP.NET in C# and Flask in Python.

- In C#, we use an aspect-oriented programming to invoke the enforcement mechanism.
- In Python, we use function decorators to directly call the enforcement mechanism.

When the privacy policies change, our model transformations would regenerate a correct enforcement mechanism automatically.

Methodology

We propose a tool-supported model-driven development methodolgy that incorporates privacy policies into the system design. Namely, we extend the approach of Basin et al. [2] with a new privacy model with precise semantics for specifying these privacy policies.

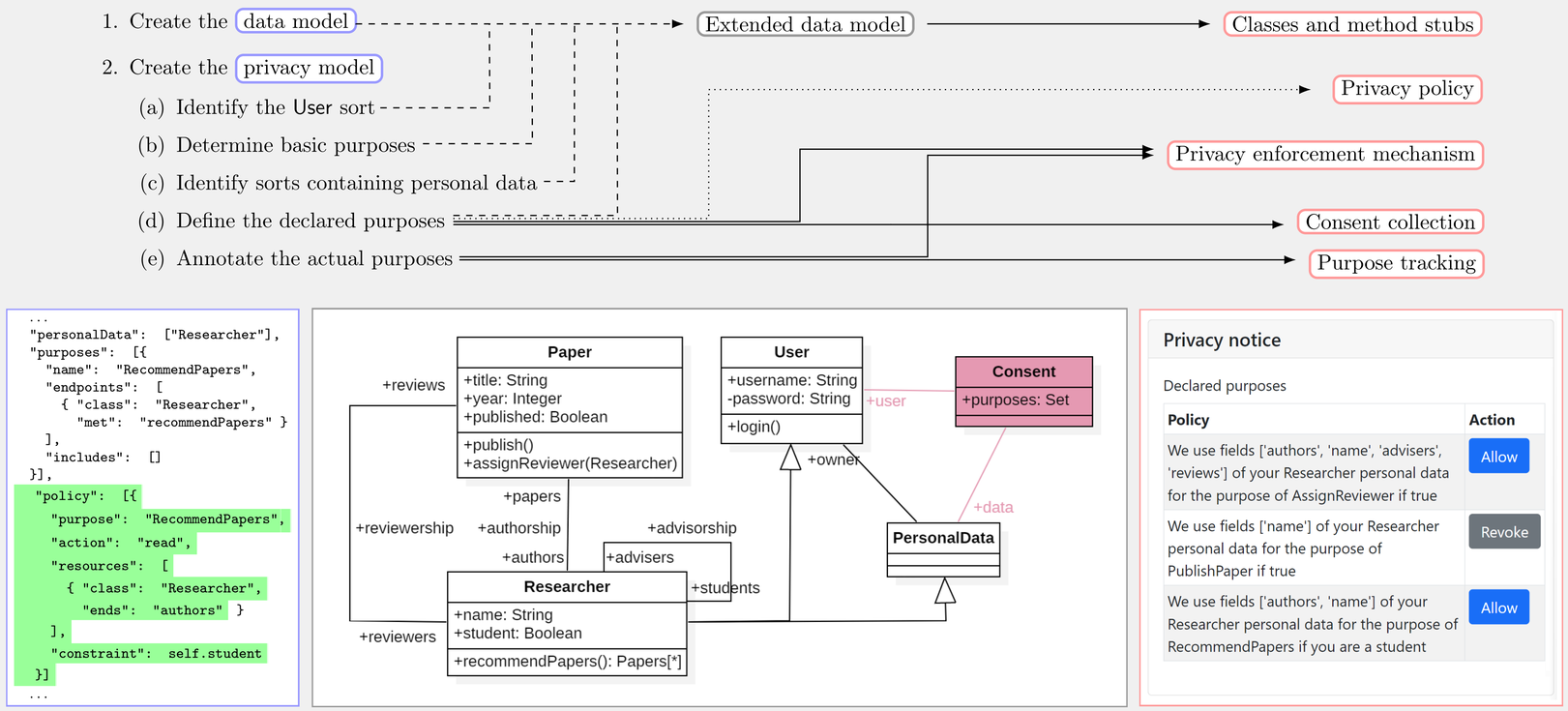


Figure 1: Overview of the model-driven privacy methodology
: input models, : intermediate artifacts, : output artifacts, ⋯→: model-to-model transformation, ⟶: model-to-code transformation, ⋯⋯: model-to-text transformation
(from left to right: the input privacy model, the extended data model, and the generated privacy notice)

Evaluation

Development effort Our approach significantly reduces the development effort (compared to implementing the same application manually).

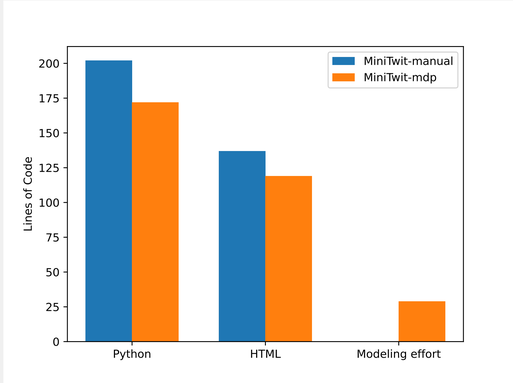
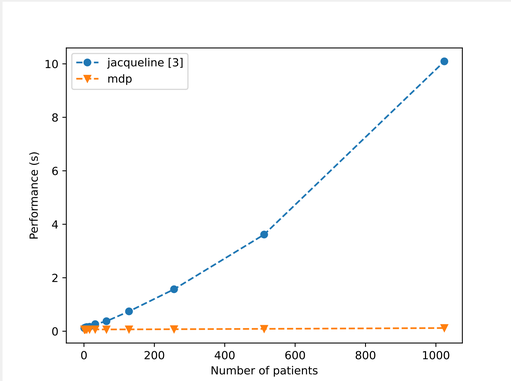


Figure 2: We implemented MiniTwit, an X cloned application in which registered users can write messages, follow and unfollow users, and view their own timeline; manually, and using our approach.

Performance overhead Our approach's performance overhead is modest and on-par with the current state-of-the-art [3].

Figure 3: HIPAA is a web application that allows users with different roles to view personal medical records.



References

[1] Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation). *Official Journal of the European Union*, 2016.

[2] David A. Basin, Jürgen Doser, and Torsten Lodderstedt. Model driven security: From UML models to access control infrastructures. *ACM Transactions on Software Engineering and Methodology (TOSEM)*, 15(1):39–91, 2006.

[3] Jean Yang, Travis Hance, Thomas H. Austin, Armando Solar-Lezama, Cormac Flanagan, and Stephen Chong. Precise, dynamic information flow for database-backed applications. In Chandra Krintz and Emery D. Berger, editors, *37th ACM SIGPLAN Conference on Programming Language Design and Implementation (PLDI)*, pages 631–647. ACM, 2016.